

HESP：在本地 LLM 告警分诊智能体中 把“探什么”与“何时停”分开

Zhuowen Liu

北陆先端科学技术大学院大学 (JAIST) 网络安全实验室

日本石川县能美市

s2410431@jaist.ac.jp

Zhixuan Wang*

辽宁师范大学美术学院

中国辽宁省大连市

wangzhixuanwzx@gmail.com

* 通讯作者

摘要—安全运营中心 (SOC) 收到的告警远多于分析师能调查的数量；无法把遥测数据发送给托管模型的组织，只能在自有硬件上用小型开源权重 LLM 来自动化分诊。让小型本地模型自己执行调查时，它们在流程上失败：不断探测却不收敛、从不给出结论，或把真实攻击判为良性。我们研究把调查流程移出模型之后会发生什么。HESP 是一个控制器：它维护一个记录相互竞争的解释的账本，按“每单位成本的期望信息增益”挑选只读探针，只接受有当前证据支撑的结论，能自行结束调查，并在每次观测之前先把预测写入日志。我们用来自两个家族的五个开源权重模型 (7B 到 72B) 做了四项预注册研究，在我们自己搭建的受控分诊环境中共计 7,272 个经过审计的回合。把流程移出模型，使 Qwen2.5-7B 的已验证完成率从 0.125 提升到 1.000，使从不自行下结论的 Llama-3.1-8B 从 0 提升到 0.917；信息增益排序在每个会下结论的模型上带来 +0.26 到 +0.35 的提升。完全不含 LLM 的控制器本身就达到 0.917。在这个环境中，每个起因都会产生一个独特的离散观测，所以起作用的是流程而不是模型，模型可测的贡献只限于等到确认证据再停止。因此，我们的结果说明的是小型本地模型不应掌控调查流程，而不是控制器让它们成为更好的调查者；在观测模糊、必须从原始日志中读取的情形下，模型能否带来价值仍未检验。我们公开全部代码、协议和回合日志。

1. 引言

告警触发后，分析师要判断它的起因：正在进行的攻击、配置错误、经授权的活动，还是误报。分析师通过查询认证日志、请求模式、配置、变更工单和威胁情报来缩小候选解释的范围；当某条观测支持一种解释、其余解释都被排除时，就停止调查。结论决定该事件是否升级处理，而每一次查询都要花时间。

手工做这件事无法扩展。告警数量超出分析师的调查能力，而且大多数告警最终是良性的 [1]。能自己选择查询、阅读结果的 LLM 智能体天然契合这个循环。然而，许多组织不能或不愿把原始遥测数据发送给托管模型。对它们来说，现实的选择是一个小到能在单块本地 GPU 上运行的开源权重模型；而近期关于 LLM 驱动的攻击调查的工作已经报告，这类模型在复杂案例上落后于闭源模型 [2]。

自动化分诊和调查的工作大体沿两条路线展开。第一条构建主机活动的溯源图，并用固定规则或学习模型对其排序或摘要 [1, 3]。这类系统减少了分析师需要阅读的

内容，但不决定下一步运行哪个查询。第二条使用 LLM 智能体来选择查询并解释结果 [2, 4]，采用 ReAct 模式，即每一步都由模型决定 [5]。这些智能体把调查流程交给模型，而对小型本地模型来说，失败的恰恰是流程。在我们的预注册研究中，自己选择探针的 Qwen2.5-7B 只在 8% 到 13% 的分诊案例中以已验证的结论结束：它一直探测直到预算耗尽。Llama-3.1-8B 从不下结论。在 3,389 次决策中，它每次都要求再多一个探针，即使证据已压倒性充分、也已没有合法探针可用。更大的模型会下结论，但在没有引导的情况下，其引用中有 22% 到 31% 是无效证据，并把 25% 到 37% 的需处置事件判为良性。

本文提出 HESP，一个把调查流程放在本地 LLM 智能体之外的控制器。一次调查由两个决策组成：下一步探什么，以及证据何时已足够；控制器可以接管其中之一或两者都接管。HESP 维护一个记录相互竞争的解释的账本，用表格按贝叶斯规则更新；这些表格说明每个探针在每种解释下会返回什么。它按每单位成本的期望信息增益为只读探针排序，只接受有当前支持性观测的结论，并能自行结束调查。模型仍然是规划器：它读取账本，可以提议探针、给出结论或放弃。每条预测都在其观测之前写入日志，每个回合事后都会被审计。

我们用来自两个家族的五个开源权重模型 (7B 到 72B) 做了四项预注册研究，在受控的分诊环境中共 7,272 个经过审计的回合。从无 LLM 的开发回合中计数得到的表，把 Qwen2.5-7B 的已验证完成率从 0.125 提升到 1.000，与从环境生成器直接得到的表持平。在规划器所获信息保持不变的情况下，信息增益排序在每个会下结论的模型上带来 +0.26 到 +0.35 的提升。控制器侧停止把 Llama-3.1-8B 从 0 提升到 0.917；在此之后，控制器选探针对它不再带来可检测的完成率提升，而 Qwen2.5-7B 两部分都需要。完全不用 LLM 的控制器本身完成 0.917 的案例；最好的 LLM 配置达到 1.000，因为强模型会等到确认性证据出现才下结论。因此在我们的环境中，收益来自把流程从模型手中拿走，而不是模型调查得更好：每个起因都会产生一个独特的离散观测，环境自己把响应翻译成这些观测，似然表和验证器也都来自同一个生成器。我们据此解读结果：它说明的

是“谁应该掌控流程”，至于模型在观测模糊时能否有所贡献，本文没有回答。

概括而言，本文的贡献如下：

- 我们表明，小型本地 LLM 在告警分诊上的失败发生在流程层面，并且“选择探什么”和“决定何时停”是两种独立的失败，在规模相近的模型之间也各不相同 (§3, §6.3)。
- 我们设计、实现并开源了 HESP¹，一个为本地 LLM 规划器接管假设账本、探针选择、结论接受和停止的控制器，带有预写日志和逐回合审计 (§4)。
- 我们用五个开源权重模型做了四项预注册研究，采用冻结的协议和源码哈希、在不同选择器之间保持规划器提示不变的盲对照，以及把探针选择与停止分开的析因设计 (§5, §6)。
- 我们表明，在这个环境中，完全不含 LLM 的控制器完成 0.917 的案例，与放入控制器的五个模型中的四个持平，因此可测的收益来自流程本身；剩余的差距来自强模型等待确认证据 (§6.3)。从同一生成器的少量无 LLM 运行中计数得到的似然表，与生成器自身的表一致，而由模型给出的表则不行 (§6.1)；由于计数和评估共用生成器，这只说明似然表不必手写，不说明它能迁移到真实数据。
- 我们测量了三个公开安全数据集，说明为什么它们都无法检验调查策略，并给出一个基于真实攻击遥测记录的案例研究，展示这些数据集所缺少的那类案例 (§6.5)。

2. 背景

2.1. 告警分诊

告警分诊紧随检测之后：对每条告警，分析师判断实际发生了什么、是否需要响应 [1]。攻击调查从一个关注点出发重建完整的攻击过程 [2, 3]；分诊则以单一结论结束，即告警的起因以及支撑它的证据。分析师通过查询环境得出结论。不同查询的成本不同，区分候选解释的能力也不同。有些查询便宜，并且对某一种解释有决定性；另一些，例如威胁情报查询，既慢，又对多种攻击返回同样的答案。因此查询的顺序决定调查多快结束，分析师还必须判断证据何时已经足够。

设想一条告警报告 Web 层认证失败和 HTTP 错误激增。它看起来像撞库 (credential stuffing)，但同样的症状也可能来自 SQL 注入探测、经授权的漏洞扫描、被误判为攻击的健康检查，或暴露在公网上的管理面板。对头部来源做威胁情报查询，可能会说它是恶意的——而这个答案是其中三种起因共有的。读取管理面板的配置，只需一次便宜的查询，就能立刻判定最后一种解释；但只有始终把这种解释放在视野里的调查者才会去运行它。

1. 代码、冻结的协议、预测表、结果文件和回合日志见 <https://github.com/lzwhehe/HESP>。

2.2. 本地 LLM 智能体

LLM 智能体把语言模型与工具结合在一起。每一步，模型读取任务和已有观测，然后调用一个工具或结束任务 [5]。在此基础上的扩展加入了语言化的自我反思 [6]，或学习何时调用工具 [7]。在安全领域，这类智能体已被用于渗透测试 [8]、夺旗赛 (CTF) 题目 [9]，以及基于安全日志的调查 [2, 4]，大多使用大型托管模型。Qwen2.5 和 Llama 3.1 等开源权重模型则可以在组织自己的硬件上运行；经过 4 比特权重量化，最大 72B 参数的模型可以放进单块 GPU。本地部署让遥测数据留在本地，代价是模型能力变弱，而在智能体循环中，每一步的决策都依赖这个更弱的模型。

3. 动机

3.1. 挑战

当小型本地模型主导调查时，会出现三个挑战。我们在各项研究的基线配置 (§5) 中逐一测量了它们；在这些配置里，模型自己选择探针。

❶ **探测却不收敛。**自己选择探针的 Qwen2.5-7B 只验证了 0.083 到 0.125 的案例。它每个回合运行约七个不同的探针，花掉 10 个成本单位中的 9.4 到 9.5 个，在 72 个回合里只有 6 或 7 个给出了结论；四分之三的回合以工具预算耗尽结束。把它的选择换成均匀随机的选择，完成率提高 +0.556 (§6.2)，说明它自己的选择比随机还差。

❷ **从不决定停止。**Llama-3.1-8B 在全部 3,389 次决策中每次都要求再运行一个探针，包括账本后验已超过 0.999、且提示中已说明没有合法探针可用的时候。它的输出始终是合法的 JSON；它只是从不结束。更好的探测帮不了一个从不给出结论的模型。

❸ **没有支撑的结论。**更大的模型会下结论，但并不总是基于证据。在没有账本的情况下，Qwen2.5-32B 和 72B 把 25% 和 37% 的需处置事件判为良性，引用中分别有 22% 和 31% 是无效证据 (§6.4)。在分诊中，把真实攻击判为无害的结论代价最高，因为事件会在未作响应的情况下被关闭。

3.2. 我们的方案

下面说明 HESP 如何应对这些挑战。

❶ **在模型之外做信息增益选择。**HESP 按每单位成本对候选起因不确定性的期望降低量，为每个合法探针排序，并执行排名第一的探针，不论模型提议的是什么。排序所依据的似然值从无 LLM 的开发运行中计数得到，而不是让模型给出——模型给不出来：模型给出的表使完成率只有 0.069 到 0.375 (§6.1)。

❷ **控制器侧停止。**在每次调用规划器之前，HESP 应用一条明确的接受规则。一旦领先起因的后验至少为 0.8、且有一条当前观测支持它，控制器就自行下结论并引用该证据。模型仍可以更早结束，因此强模型保留了等待确认证据的选择。

③ 受证据约束的结论。HESP 只接受引用了当前观测、且该观测提高了所声称起因分数的结论。一个规划器无法访问的独立验证器，会用只有该起因才会产生的特征来检查每个结论；预写日志使审计能够重放每一步。

4. 方法

HESP (Hypotheses → Evidence → State → Planning, 即假设 → 证据 → 状态 → 规划) 是一个位于本地 LLM 规划器和只读探针目录之间的控制器 (图 1)。规划器负责提议；控制器决定运行哪个探针、接受哪个结论、调查何时结束。工作流程分两个阶段：

- 1) 建表：部署之前，无 LLM 的开发运行在起因已知的案例上执行每个探针，HESP 把结果计数成预测表 (§4.1)。
- 2) 调查：对每条告警，HESP 维护一个假设账本 (§4.2)，选择要运行的探针 (§4.3)，并对每个结论应用证据规则和停止规则 (§4.4)。规划器读取账本并提出决策。每一步都在其观测之前写入日志，事后接受审计。

范围与假设。 HESP 运行在组织内部网络中，以一个本地开源权重模型作为规划器，并通过固定的探针目录只读地访问安全遥测：认证和 HTTP 日志、来源信誉、DNS 日志、配置、资产清单、变更工单和威胁情报。结论交给人类分析师；智能体从不做修复操作，也从不向被调查的系统发送流量。告警可能由攻击者引起，攻击者控制着智能体所读证据的一部分，例如请求载荷、User-Agent 或命令行，并希望调查以良性结论结束，或根本没有结论。我们信任控制器、它的表、探针实现和日志，不信任规划器会遵循合理的流程。于是，无论规划器输出什么，以下三条性质都成立：(i) 每个被执行的探针都在只读目录中、预算负担得起、且在当前状态下尚未运行过；(ii) 每个被接受的结论都至少引用一条提高了所声称起因分数的当前观测；(iii) 每条预测都在它所预测的观测之前写入日志。HESP 不保证结论正确，正确与否取决于表以及假设集合是否包含真实起因。证据篡改、通过日志内容进行的提示注入、以及生成新假设，都不在本文范围内。

4.1. 预测表

账本和选择器都需要：对每个探针 a 和起因 h ，给出该探针结果词表上的分布 $P(o | h, a)$ 。HESP 通过计数来估计这些表。一个不涉及任何 LLM 的穷举脚本，在每个起因的每个开发实例上把每个探针运行 k 次，记录结果，并以 $\varepsilon = 0.01$ 平滑归一化计数。这些表在任何评估回合运行之前写入磁盘、计算哈希并冻结；一个单元测试保证估计器从不调用环境的生成函数。实际部署时，开发案例可以来自已结案的工单或重放的事件 (§7)。

让规划器自己给出似然值可以省去开发数据，但小模型给不出来 (§6.1)。相比之下，在我们的环境中，计数方法每个案例只需五个回合就够用。

示例。 在贯穿示例所用的计数表中 ($k=20$)，探针 `admin_exposure` 在管理面板暴露时以 0.995 的概率返回已暴露、无认证，在其余七个具名起因下各为 0.005。探针 `source_ips` 在撞库下以 0.992 的概率返回大量住宅 IP，在其余每个具名起因下为 0.002。

4.2. 假设账本

一个回合从一条告警和一个有限的候选起因集合 $\mathcal{H}$ 开始，其中包含一个显式的其他 (other)。智能体可以运行只读探针 $a \in \mathcal{A}$ ，每个探针有成本 $c(a)$ ，返回有限词表中的一个结果 o 。预算限制探针数量、总成本、规划器决策次数和墙钟时间。回合以一个结论 (h, E) 结束 (E 是被引用的观测集合)，或以放弃结束，或以预算耗尽结束。若 h 是当时生效的起因，且 E 中包含一条只有该起因才会产生的当前观测，则结论正确。

账本保存 $\mathcal{H}$ 上的后验 $p(h)$ ，从均匀先验开始。观测到探针 a 的结果 o 后，它用冻结的表应用贝叶斯规则，并对每个起因记录这条观测是提高、降低还是没有改变它的分数 (支持、反对、中性)。暂时性故障 (如 HTTP 503) 会被记录，但不算证据，该探针可以重试。在所有起因下都不可能出现的结果标志着表冲突，会被跳过。环境暴露一个状态版本。当事件在智能体调查过程中发生变化时，版本号递增，当前分数重置为先验；较早的证据仍保留在记录中，但不再算作当前证据。

示例。 贯穿示例的告警报告认证失败和 HTTP 错误激增，此时九个候选各为 0.111。第一个探针 `source_ips` 返回正常，四个起因仍然可能，各为 0.238。第二个探针 `access_pattern` 也返回正常，剩下三个各为 0.327；暴露的管理面板、有漏洞的组件、DNS 命令与控制。第三个探针 `admin_exposure` 返回已暴露、无认证，把暴露的管理面板推到 0.966。

4.3. 探针选择

对每个合法探针 (当前状态下未试过、预算负担得起、前置条件已满足)，控制器计算期望信息增益

$$\begin{aligned} \text{EIG}(a) &= H(p) - \sum_o P(o | a) H(p(\cdot | o, a)), \\ P(o | a) &= \sum_h p(h) P(o | h, a), \end{aligned}$$

其中 H 是香农熵， $p(\cdot | o, a)$ 是观测到 o 之后的后验。它按 $\text{EIG}(a)/c(a)$ 为探针排序，并执行第一名，不论规划器提议的是什么。

规划器设计。 每一步，规划器收到一个渲染成文本的结构化请求：任务、候选起因、带成本和结果说明的探针目录、已有观测、账本、被拦截提议的反馈，以及剩余预算 (附录 A 原样给出一个例子)。它返回一个 JSON 决策：`action` (提议一个探针)、`finish` (一个起因加上所引用观测的 ID) 或 `stop` (放弃)。无效回复会连同错误信息返回给模型，允许重试一次。我们评估的各配置区别在于是否向规划器展示控制器的排序。盲配置只说明由控制器挑选探针，既不展示排序也不展示选择器，因此无论运行哪个选择器，提示都完全相同，这一点由单

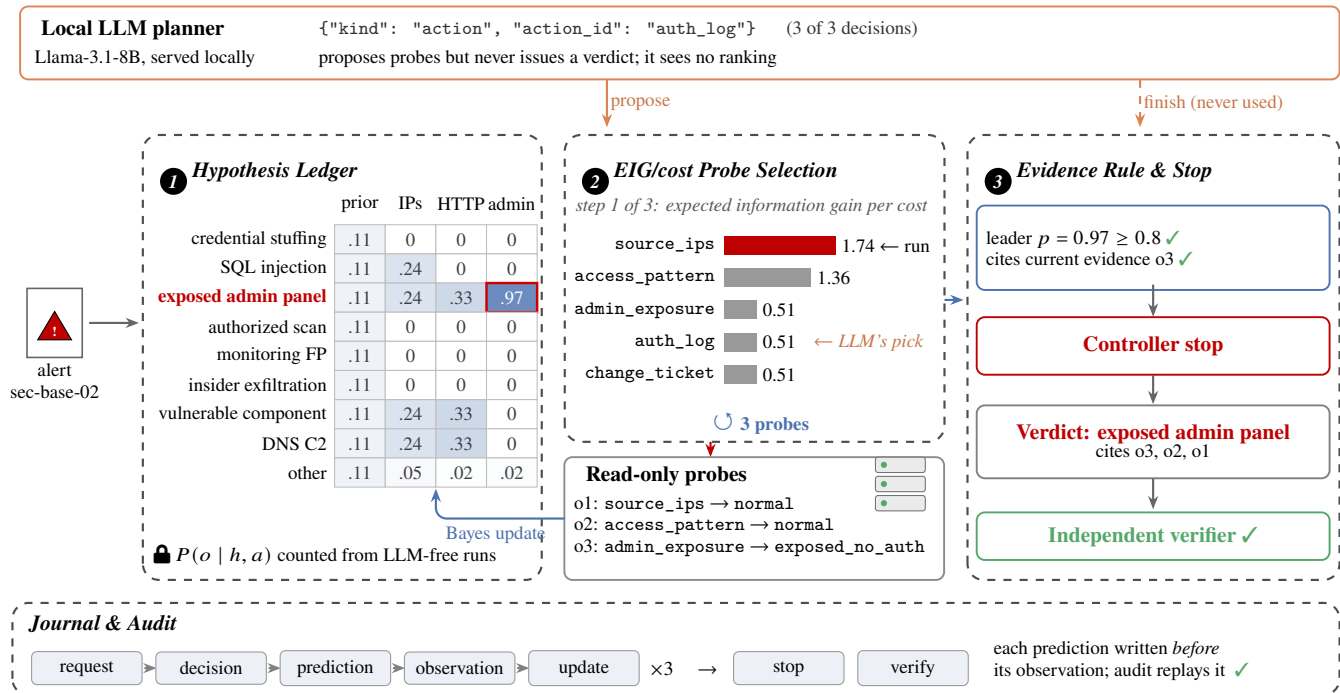


图 1. HESP 总览，以本节的贯穿示例绘制（规划器为 Llama-3.1-8B；真实起因是暴露的管理面板）。① 假设账本保存候选起因上的后验，按贝叶斯规则用冻结的探针一结果表更新。② 每一步之前，控制器按每单位成本的期望信息增益为合法探针排序并运行第一名；规划器的提议（此处三次都是 `auth_log`）只是建议。③ 一旦领先者的后验达到 0.8 且有当前观测支持它，控制器下结论并引用该证据，由独立验证器检查结论。每一步都在其观测之前写入日志，事后接受审计。所有数值取自归档日志。

元测试检查。随机选择器在合法探针中均匀挑选，作为对照。

示例。在贯穿示例中，Llama-3.1-8B 在它的三次决策中都提议了 `auth_log`。排序在第一步之前把这个探针估为每成本单位 0.51 比特（`source_ips` 为 1.74），在第三步之前估为 0.04，而那时 `admin_exposure` 以 0.86 领先。控制器实际运行的是 `source_ips`、`access_pattern` 和 `admin_exposure`。

4.4. 证据规则、停止与验证

状态守卫的结束。规划器的 `finish` 只有在所声称起因的当前分数至少为 $\tau = 0.8$ 、且至少一条被引用观测是支持它的当前状态证据时才被接受。被拒绝的结束请求会作为反馈返回给规划器。

控制器侧停止。控制器也可以自行下结论。在每次调用规划器之前，以及预算耗尽时，它对当前领先者应用同一条接受规则。如果规则满足，它引用至多三条支持性的当前状态观测，并结束回合。规划器仍可以更早结束或放弃，而它的提示中没有任何内容透露这条规则。

独立验证器。只有当所给起因等于当时生效的起因、且至少一条被引用的当前状态观测带有只有该起因才会产生的特征时，结论才算已验证。纯靠排除法得到的结论，或仅由多种攻击共有的通用“恶意”威胁情报命中支撑的结论，都不算验证通过。规划器无法访问验证器。

日志与审计。每次规划器请求和决策、每条预测、观测和账本更新，以及验证，都追加写入日志，并且每条预测都在它所预测的探针运行之前写入。每个回合结束后，审计会重放日志，检查事件顺序、观测来源、计数器、预算、引用，以及控制器做出的每个结论是否满足其规则。

示例。在贯穿示例中第四次调用规划器之前，暴露的管理面板以 0.966 领先，第三条观测支持它，于是控制器下结论并引用了全部三条观测。验证器确认了该结论，因为第三条观测带有暴露面板自身的特征。这个回合用了三个探针、三个成本单位，耗时 5.1 秒。在控制器选探针相同但没有停止规则的情况下，同一模型在第三步得到同一条观测，却始终没有下结论（图 2 第二行）。

5. 评估设置

为评估 HESP，我们围绕四个问题组织评估：

- 1) 可靠性：HESP 能否让小型本地模型成为可靠的分诊智能体？它是否依赖对环境的神谕知识？ (§6.1)
- 2) 排序还是剥夺选择：收益来自信息增益排序，还是仅仅来自把选探针的权力从模型手中拿走？ (§6.2)
- 3) 探测还是停止：“选择探什么”和“决定何时停”是否是两种独立的失败？每个模型各有哪一种？ (§6.3)

- 4) 失败方式：从安全角度看，结论是如何出错的呢？ (§6.4)

每个问题都对应一项预注册研究，每项研究都在上一项运行完成之后才设计（表 1）。§6.5 进一步追问：公开安全数据能否检验同样的问题。

5.1. 环境与表

5.1.1. sec-triage 环境. 每个回合是一个 Web 服务上的一条告警。隐藏起因是八种解释之一：三种攻击（撞库、SQL 注入探测、DNS 命令与控制）、一名正在外泄数据的内部人员、一个暴露的管理面板、一个已知有漏洞的组件、一次经授权的漏洞扫描，以及一次监控误报。假设集合再加上其他。十个只读探针，每个成本 1 到 3 单位，覆盖认证失败、HTTP 模式、来源信誉、管理面板暴露、按用户的出站流量、DNS 特征、组件清单、变更工单、威胁情报和一本通用操作手册。我们有意让捷径失效。威胁情报只会说某个指标是恶意的，而三种攻击共享这个答案。操作手册不含任何信息。有几种良性起因在运行正确的探针之前看起来都像攻击。每种起因有三个变体。*base* 中，结果是确定的，只有 10% 的威胁情报延迟。*noise* 增加 15% 的暂时性 HTTP 503 故障和 30% 的延迟。*drift* 中，事件在第二个探针之后被替换：状态版本递增，真实起因改变。由此得到 24 个任务，每项研究在每种配置下把每个任务运行三次。每个回合由它自己的回环 HTTP 沙箱提供服务。

5.1.2. 预测表. 我们比较 $P(o|h,a)$ 的三种来源。设计者表来自环境的生成函数，作为神谕参照。计数表（表格中记为“empirical”）按 §4.1 的方法估计，每个起因和变体用 $k \in \{1, 5, 20, 100\}$ 个开发回合，只用 *base* 和 *noise* 变体，种子取自与评估不相交的空间。模型自报表由规划器 LLM 自己给出。每张表都在任何评估回合运行之前冻结并计算哈希。由于开发回合和评估回合来自同一个生成器，计数表告诉我们需要多少观测才够，而不能说明方法在陌生环境中的表现。

5.2. 实验设计

5.2.1. 配置. 所有配置使用相同的模型、提示模板、探针目录、预算（10 次工具调用、10 个成本单位、12 次决策、900 秒）、重复拦截和验证器。*ReAct-style* (ReAct 式)：规划器只看到原始观测历史，每个探针都由它选。*Memory-only* (仅记忆)：规划器还能看到账本，但仍由它选每个探针。*HESP*：由控制器选探针（EIG/成本或随机），可展示或不展示排序，可带或不带结束守卫和控制器侧停止。图 2 在同一条告警上展示了其中四种配置。停止研究之后，我们还用一个按目录顺序提议探针、从不结束脚本替换 LLM，运行了冻结的控制器。这个无 LLM 参照使用停止研究的种子、任务、预算和表（216 个回合）；它没有预注册，我们把它作为探索性结果报告。

5.2.2. 实现. HESP 约 2,900 行 Python，只用标准库。规划器可插拔：同一个 JSON 决策协议同时服务 vLLM 和 Ollama 端点，以及无 LLM 运行所用的脚本化策略。每个回合有自己的回环 HTTP 沙箱，因此探针是真实的 HTTP 请求，带有暂时性故障和状态变化，任何回合都无法观察到另一个回合。每项研究都使用 Qwen2.5-7B-Instruct (bf16)、Qwen2.5-32B-Instruct-AWQ 和 Qwen2.5-72B-Instruct-AWQ；分解研究和停止研究另加 Llama-3.1-8B-Instruct (bf16) 和 Llama-3.1-70B-Instruct-AWQ-INT4。模型由 vLLM 在单块 RTX 6000 级 GPU 上提供服务，温度 0.2，每次调用使用不同的种子。一个成对、打乱顺序、可续跑的运行器最多同时执行 32 个回合；如果清单或控制器源码的哈希发生变化，它会拒绝续跑。每个模型跑完后，它审计全部回合、归档日志，并记录归档文件的 SHA-256。停止研究的 1,800 个回合用时 28 分钟。一套 145 个单元测试覆盖账本、选择器、盲提示、守卫、控制器停止、审计，以及表估计器与环境生成器之间的隔离。

5.2.3. 评估方法. 每项研究的假设、配置、主要终点和分析方法，连同源码和表的哈希，都在其任何回合运行之前写下并冻结；冻结之后的改动以勘误形式追加（附录 B）。结果指标是已验证完成率，即以已验证结论结束的回合所占比例。其他任何结束方式，包括超时和格式错误的输出，都算失败。我们报告按任务配对的差值，以及百分位数的任务簇自助法区间（2,000 次重抽样，24 个簇）。当一项研究有两个主要终点时，每个终点使用 Bonferroni 校正后的 97.5% 区间；所有次要比较都是探索性的，未做校正。我们还报告描述性的安全指标。有两种起因是良性的（经授权的扫描和监控误报），其余六种需要处置。在以结论结束的回合中，漏报攻击率是真实起因需处置、而结论给出良性起因的比例；误升级率则相反；错因率是结论给错起因的比例。未解决率是所有回合中没有已验证结论的比例。真值是给出结论那一刻生效的起因。所有表格和图都由脚本从原始结果文件生成。

6. 评估结果

6.1. 可靠性

初始研究（1,944 个回合，设计者表）比较了完整的 HESP (EIG/成本选择加结束守卫) 和 Memory-only；在后者中，规划器看到同样的账本，但自己选探针。Qwen2.5-7B 的已验证完成率提高了 +0.889 [+0.75, +1.00]，32B 提高了 +0.250 [+0.10, +0.42]。72B 的提升为 +0.111，区间触及零 [0.000, +0.236]。收益随模型规模缩小，与预期一致。这项研究留下一个悬而未决的问题，因为它的表来自环境生成器：收益是否需要神谕知识？表来源研究用计数表替换了设计者表，唯一的主要终点是 7B 与 Memory-only 的比较。表 2 报告了每种表来源下的已验证完成率。

有三点发现值得关注。第一，计数表与神谕持平。用每个起因和变体 $k=20$ 个开发回合计数得到的表，

表 1. 四项在 SEC-TRIAGE 上的预注册研究总览，共 7,272 个回合。仓库中按版本号标记这些研究。

研究	版本	问题	模型	回合数	主要终点
初始研究	v0.5	控制器有没有用？	3 个 Qwen	1,944	完整 HESP 对 Memory-only，逐模型
表来源研究	v0.6	表必须来自神谕吗？	3 个 Qwen	1,728	计数表 HESP 对 Memory-only，7B
分解研究	v0.8	排序还是剥夺选择？加入第二个家族	5	1,800	排序对随机（Q-7B）；HESP 对 Memory-only（L-8B）
停止研究	v0.9	探什么 vs. 何时停	5	1,800	控制器停止；给定停止后的选择（均为 L-8B）

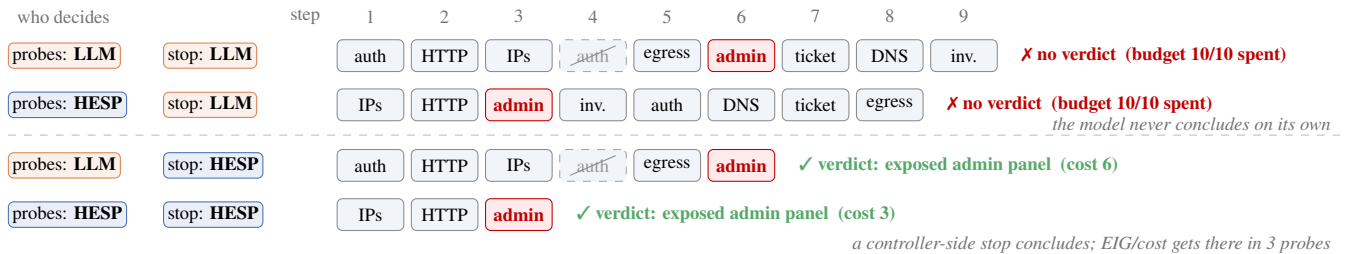


图 2. 同一条告警、同一个本地模型、四种划分调查的方式。告警的真实起因是暴露的管理面板；每一行的规划器都是 Llama-3.1-8B，种子相同。每个小块是一个实际运行的探针（虚线：被控制器拦截的重复提议）；红色标出确认起因的那条观测。当由模型决定何时停止时（前两行），它拿到了决定性证据，却继续探测直到预算耗尽。控制器侧停止会下结论（后两行），而信息增益选择只用三个探针就做到了。四行均原样取自停止研究的归档日志。

表 2. 表来源研究：按预测表来源划分的已验证完成率（每格 72 个回合）。7B 与 MEMORY-ONLY 的比较是预注册的主要终点；32B 和 72B 为探索性结果。区间为 95% 任务簇自助法区间。表中 EMPIRICAL 即计数表。

Arm	Qwen2.5-7B	Qwen2.5-32B	Qwen2.5-72B
ReAct-style	0.028	0.611	0.597
Memory-only	0.125	0.750	0.889
HESP, empirical table ($k=20$)	1.000	1.000	1.000
HESP, designer table	1.000	1.000	1.000
HESP, LLM-elicited table	0.069	0.375	0.375
Δ empirical – Memory-only	+0.875 [+0.74, +0.97]	+0.250 [+0.10, +0.42]	+0.111 [+0.00, +0.24]
Δ designer – empirical	+0.000 [+0.00, +0.00]	+0.000 [+0.00, +0.00]	+0.000 [+0.00, +0.00]
Mean probe cost, Memory-only / empirical	9.44 / 9.40	5.39 / 6.11	5.71 / 5.33

HESP 把 Qwen2.5-7B 从 0.125 提升到 1.000 (+0.875 [+0.74, +0.97]；22 个任务更好，没有任务更差），并且在三个模型上的完成率都与设计者表相同。 $k=5$ 时已经饱和， $k=1$ 时每个模型最少一个回合。这种饱和反映的是环境几乎是确定性的，而不是一种普遍的数据效率性质。

第二，不是神谕的代价只集中在一行。计数表比设计者表每回合多花 1.2 到 2.4 个探针单位。一次无 LLM 检查把全部差距定位在其他这一行，也就是开发数据中从未出现过的那个起因。只把其他这一行换成设计者的，就能精确恢复完成率和成本：在脚本化设置下，从 0.875、3.53 单位变为 1.000、2.54 单位。

第三，模型无法自己写出这些表。使用规划器自报的表时，7B、32B 和 72B 模型的完成率分别降到 0.069、0.375 和 0.375。在结束守卫下，32B 和 72B 模型对撞库、SQL 注入、DNS 命令与控制、暴露的管理面板、有漏洞的组件所引起的案例一个都没完成，而其余三种起因的案例全部完成。因此，控制器必须同时提供流程和表中所编码的知识。

6.2. 排序还是剥夺选择

由控制器挑选探针会同时改变两件事：去掉了模型自己的选择，并用一个排序替代了这个选择。分解研究用盲配置把两者分开：无论使用哪个选择器，规划器收到的提示都相同；同时加入 Llama 3.1 家族。它的主要终点是 Qwen2.5-7B 上的排序效应（盲 EIG/成本对盲随机），以及 Llama-3.1-8B 上完整 HESP 对 Memory-only。图 3 为每个模型展示了收益的两个组成部分；附录 C 列出了全部数值。

有三点发现值得关注。第一，排序本身有用。在规划器信息相同的情况下，EIG/成本选择在 Qwen2.5-7B 上比随机选择高 +0.306 [+0.14, +0.47]，证实了第一个主要终点。在每个会下结论的模型上效果相近：Qwen 32B、Qwen 72B 和 Llama 70B 上分别为 +0.35、+0.35 和 +0.26，区间都不含零。

第二，剥夺选择对弱模型有帮助，对强模型有害。把模型自己的探针选择换成随机选择，7B 模型的完成率提高 +0.556，因为它自己的选择比随机还差；而 Qwen

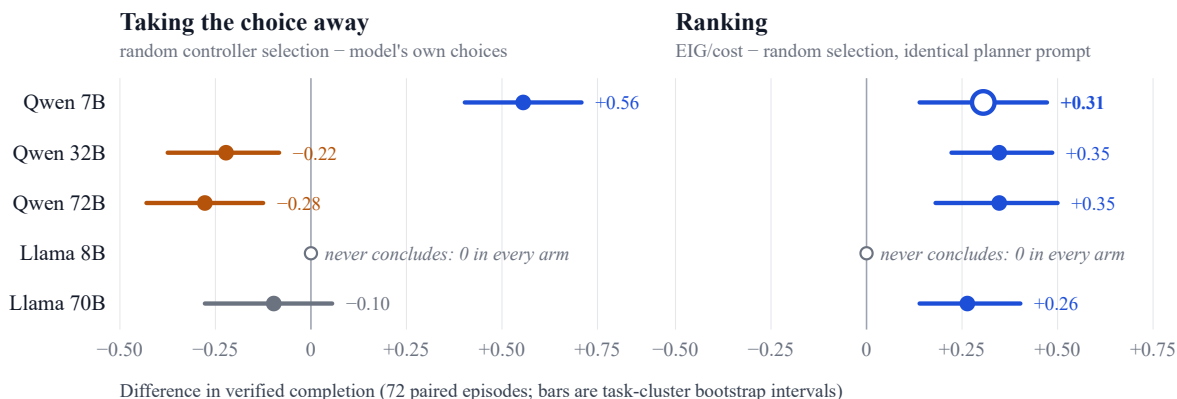


图 3. 分解研究：相对于 Memory-only 的收益来自哪里，逐模型展示（已验证完成率之差，72 个配对回合，任务簇自助法区间）。剥夺选择（Taking the choice away）比较控制器随机选择与模型自己的选择。排序（Ranking）在规划器提示完全相同时比较 EIG/成本选择与随机选择。空心标记（Qwen 7B，排序）是主要终点，使用 97.5% 区间；其余为探索性的 95% 区间。琥珀色标出完全低于零的区间。Llama-3.1-8B 从不下结论，因此它上面的每个对比都为零。

32B 和 72B 分别降低 0.222 和 0.278，因为它们的选择优于随机。因此，对小模型来说，控制器贡献的是纪律和排序；对大模型来说，控制器只贡献排序，而排序之所以能抵消失去的选择，只是因为它信息量足够大。向规划器展示排序、加入结束守卫，各自对完成率的变化都不超过 +0.06。

第三，选探针并不能让模型下结论。第二个主要终点未能证实。Llama-3.1-8B 在任何配置下 360 个回合一个都没完成：它做了 3,389 次决策，全部是要求再运行一个探针，输出始终是合法 JSON。控制器决定了探什么，但何时停仍由规划器决定。

6.3. 探测还是停止

停止研究把“谁选探针”和“谁可以停止”交叉组合，加入随机选择对照，并把两个主要终点都放在 Llama-3.1-8B 上：控制器停止能否挽救它，以及在提供停止之后控制器选探针是否仍有帮助。运行之前，一次无 LLM 模拟预测：如果模型继续从不下结论，第一个终点约为 0.9；因此我们把它视为近乎机械的结果，把第二个终点视为真正有信息量的检验。图 4 和表 3 报告了结果。

第一，控制器停止挽救了从不下结论的模型。允许控制器停止后，Llama-3.1-8B 从 0 升到 0.917 (+0.917 [+0.79, +1.00]；22 个任务更好，没有任务更差)，与预测一致。

第二，对这个模型而言，收益来自停止。提供停止之后，Llama-3.1-8B 自己选探针达到 0.861，控制器选探针达到 0.917，差值为 +0.056 [-0.07, +0.18]。该区间允许存在中等程度的收益，因此我们只能得出：对这个模型，选择没有带来可检测的完成率提升。但选择确实把探针成本减半（2.35 对 4.78 单位）。模型自己的选择表现与固定的目录顺序相当，后者在无 LLM 运行中以 4.85 单位达到 0.847。

第三，小模型的失败方式不同。仅靠控制器停止就把 Qwen2.5-7B 从 0.083 提升到 0.694，控制器选探针再

增加 +0.222 [+0.08, +0.39]（附录 C）。因此它在分解研究中的失败，部分是拒绝下结论，部分是探测不佳；而 Llama-3.1-8B 的失败几乎完全是拒绝下结论。控制器无法事先知道某个模型缺的是哪一部分，所以两部分都得提供。

第四，排序效应在全部五个模型上重复出现。在控制器停止下，EIG/成本在每个模型上都比随机选择高 +0.17 到 +0.21，包括 Llama-3.1-8B，区间都不含零。

第五，控制器靠排除法下结论，而强模型会等待确认。在本来就会下结论的模型上，允许控制器停止会使完成率降低 0.01 到 0.08。控制器停止配置的每一个失败（每个模型六个回合）都是一个正确的 DNS 命令与控制结论，由控制器排除其他可能后得出。验证器要求确认性特征，因此拒绝了它，这在运行前的协议中就已预料到。当由 Qwen 32B 和 Llama 70B 决定何时停止时，它们会继续探测直到 DNS 证据出现，并完成全部案例。唯一的其他失败是三个 drift 回合，其中 Qwen 72B 抢先以错误的起因结束。

最后，控制器本身已接近最好水平。无 LLM 运行以 2.35 单位完成 0.917 的案例，是所有配置中成本最低的。当控制器既选探针又负责停止时，五个模型中有四个也恰好得到 0.917、成本相同，说明模型在这里几乎没有贡献。超过它的配置，都是由强模型决定证据何时已足够的配置。

6.4. 失败方式

表 4 按错误类型拆分了表来源研究中的结论。这些指标是描述性的，没有预注册为终点。

有三点观察值得关注。第一，使用计数表时，HESP 在全部 216 个回合中都给出了结论，没有一个给错起因。第二，基线的失败方式随规模而变。7B 基线很少下结论，88% 到 97% 的回合未解决；而更大的 ReAct 式基线会下结论但经常出错：它们把 25%（32B）和 37%（72B）的需处置事件判为良性，引用中分别有 22% 和 31% 是

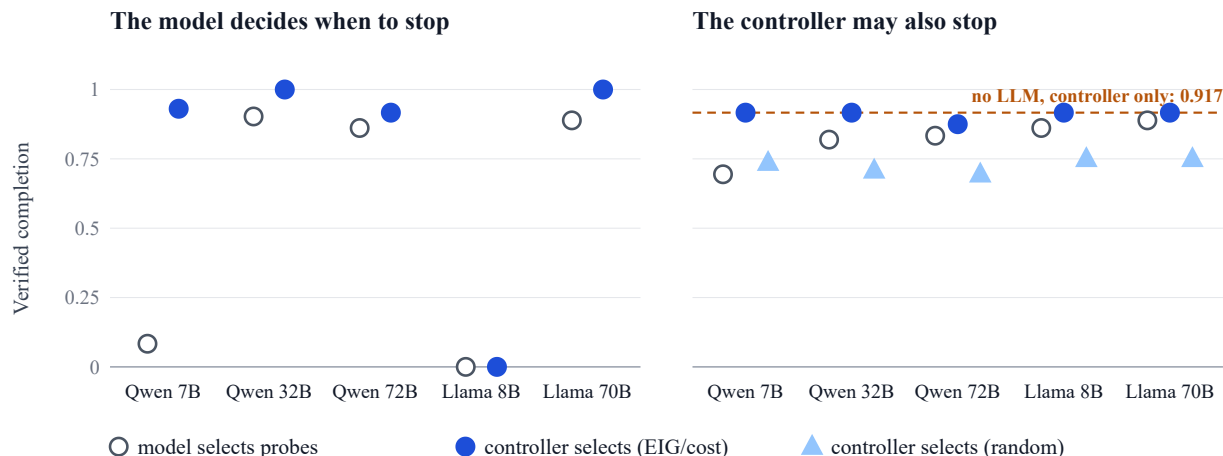


图 4. 停止研究：按“谁选探针”和“谁可以停止”划分的已验证完成率（每个点 72 个回合）。虚线是事后运行的无 LLM 控制器（EIG/成本选择加控制器停止，种子和任务相同）。

表 3. 停止研究：已验证完成率，括号内为平均探针成本，每格 72 个回合。“LLM OR CONTROLLER”：规划器仍可抢先结束。新的种子（2027）使第一行和第三行成为分解研究的独立重复。底部几行用一个从不结束的脚步替换了 LLM。

Who probes	Who stops	Q-7B	Q-32B	Q-72B	L-8B	L-70B
LLM	LLM	0.083 (9.5)	0.903 (5.2)	0.861 (5.6)	0.000 (9.7)	0.889 (8.6)
LLM	LLM or controller	0.694 (5.2)	0.819 (4.1)	0.833 (4.1)	0.861 (4.8)	0.889 (4.4)
controller (EIG/cost)	LLM	0.931 (7.2)	1.000 (5.5)	0.917 (3.6)	0.000 (10.0)	1.000 (9.0)
controller (EIG/cost)	LLM or controller	0.917 (2.3)	0.917 (2.3)	0.875 (2.3)	0.917 (2.3)	0.917 (2.3)
controller (random)	LLM or controller	0.736 (6.4)	0.708 (6.0)	0.694 (5.4)	0.750 (6.4)	0.750 (6.4)
<i>No LLM (post hoc reference, same seeds, tasks and budget)</i>						
catalogue order	controller			0.847 (4.8)		
controller (EIG/cost)	controller			0.917 (2.3)		
controller (random)	controller			0.750 (6.4)		

无效证据。第三，仅账本本身就消除了大部分这类错误：Memory-only 把漏报攻击率降到 4% 和 2%。在停止研究中，控制器选探针加控制器停止的配置在全部五个模型上都从未把需处置事件判为良性。

6.5. 公开安全数据

受控环境引出一个显而易见的问题：这些结果在真实数据上还成立吗？我们尝试用最接近的三个公开数据集来回答。下面的测量只使用训练或开发材料，并遵循同样的预注册纪律。不过，两个更早的可行性检查脚本读取过 ExCyTIn 全部 1,017 道题，其中包括 599 道测试题（勘误 E-8）；没有任何 ExCyTIn 结果用于评估 HESP，GUIDE 的测试集也始终未被读取。要检验控制器是否选对探针，需要满足三点。（i）仅凭告警本身不能揭示答案，因此必须有多种解释仍然可能。（ii）探针的成本和揭示的信息量必须不同，这样顺序才有意义。（iii）真值必须客观，反映实际发生了什么，而不是一种标注惯例。三个数据集都无法同时满足这三点。

ExCyTIn-Bench [4]。ExCyTIn 针对一个模拟 Azure 租户的日志提出问题，其答案可以从公开的调查图中机

械地恢复（1,017 个问题中的 98.5%）。在 418 个训练问题中，54.8% 在问题文本里直接点名了目标告警，其余大多数是对它的转述，因此任务变成定位被点名的告警并读出一个实体。标准的指标关联探针找到真实答案的频率并不比干扰项高（告警表中为 0.571 对 0.570），只有 19.4% 的问题存在能单独挑出答案的表。这些问题检验的是导航和检索，而不是调查。

GUIDE [10]。GUIDE 包含来自 5,340 个组织的 707,108 起真实、已匿名的事件，标为真阳性、良性阳性或假阳性。在我们基于其告警元数据定义的十个事件级探针上，组织身份本身就携带了等级 1.50 比特熵中的 1.03 比特，还有几个大型组织对每起事件都给同一个等级。在组织内部，查一下该组织以前如何给同一检测器定级，就能达到 0.911 的准确率；跨组织时，这些探针不超过多数类基线。在冷启动事件上，证据整合（AUROC 0.755）与查历史（0.759）持平（差值 $-0.004 [-0.028, +0.027]$ ）。标签反映的是组织策略，因此我们暂停了计划中的 GUIDE 研究；它的测试集至今未读。

OTRF Security-Datasets [11]。OTRF 包含执行 ATT&CK 技术时在实验室中录制的 Windows 主机遥

表 4. 表来源研究：面向安全的结果（描述性）。“CLAIMED”统计以结论结束的回合。漏报攻击（MISSED ATTACK）、误升级（FALSE ESCALATION）和错因（WRONG CAUSE）率以这些结论为分母；未解决（UNRESOLVED）率以全部 72 个回合为分母。

Model	Arm	claimed	unresolved	missed attack	false escalation	wrong cause
Qwen2.5-7B	ReAct-style	3/72	0.97	1.00	0.00	0.33
Qwen2.5-7B	Memory-only	9/72	0.88	0.00	0.00	0.00
Qwen2.5-7B	HESP (empirical)	72/72	0.00	0.00	0.00	0.00
Qwen2.5-32B	ReAct-style	69/72	0.39	0.25	0.28	0.36
Qwen2.5-32B	Memory-only	72/72	0.25	0.04	0.17	0.12
Qwen2.5-32B	HESP (empirical)	72/72	0.00	0.00	0.00	0.00
Qwen2.5-72B	ReAct-style	72/72	0.40	0.37	0.17	0.40
Qwen2.5-72B	Memory-only	71/72	0.11	0.02	0.00	0.06
Qwen2.5-72B	HESP (empirical)	72/72	0.00	0.00	0.00	0.00

测，没有良性活动的录制。我们审计了远程执行类别的 27 份录制（243,000 个事件），把每次服务安装和计划任务的创建或更新当作一条告警，并用录制自带的元数据标注。在 46 条不同的告警中，8 条是攻击，38 条是后台操作系统事件。一条只看告警文本的简单规则——判断该任务或服务是否属于 Windows 组件——在 46 条中判对 44 条，因为 8 次攻击中有 6 次被其工具的名字暴露了。

案例研究。OTRF 中唯一确实需要调查的场景，在真实日志上展示了 HESP 所针对的那类案例。它的元数据引用了微软对 Solorigate 入侵的分析 [12]，并把该活动标为远程创建计划任务（T1053.005）。告警是 WORKSTATION6 上的安全事件 4698，报告在文件夹 \Microsoft\Windows\SoftwareProtection-Platform 中新建了任务 EventCacheManager，其文件夹和名字都与真实的 Windows 任务一致；只看文本的规则判定它为良性。第一个探针发现它是域用户 THESHIRE\pgustavo 创建的，而 27 份录制中 \Microsoft\Windows 下的另外 17 个任务事件全部由机器账户创建。第二个探针发现创建它的会话是来自另一台主机的网络登录（类型 3，Kerberos），这排除了本地持久化和用户上下文更新程序。该任务以 SYSTEM 身份运行 cmd.exe，源主机的进程日志显示了创建它的 schtasks /create ... /s 命令。告警文本和调查结果指向相反的方向，两个便宜的探针就能把它们区分开。由于一个探针就足够、而且场景只有这一个，这个案例无法说明探针顺序是否重要；我们只把它作为定性证据。

共同的缺口。三个数据集的失败方式各不相同，但缺的是同一种东西：看起来像日常运维的攻击，以及看起来像攻击的日常运维。它们的良性样本是操作系统的日常维护，而不是管理员合法使用同样的工具；它们的攻击模拟留下了谨慎的攻击者不会留下的痕迹。这类成对的、客观标注的数据，是在真实遥测上评估分诊智能体的前提。

7. 讨论

局限性。所有确证性证据都来自同一个由我们设计的环境。它规模小（24 个任务）、几乎是确定性的，开发回合和评估回合共用一个生成器。这些性质在三方面有利于由似然表驱动的控制器的，合起来解释了为什么控制器单独就能达到 0.917。第一，在生成器中几乎每个起因都会在某个探针上以概率 1 产生一个独特结果，所以一个选对的探针通常就能确定起因。第二，环境自己的分类器用固定规则把每个原始响应翻译成离散结果（例如子域名熵不低于 4.0 就记为高熵），因此阅读遥测——模型最可能发挥作用的那一步——是由代码完成的。第三，计数表来自同一个生成器，而验证器的特征恰好就是这些表中的独特结果，所以计数表与设计者表一致、控制器的停止规则与验证器一致，都是由构造决定的。在证据带概率且相互重叠、似然表有误、或观测来自原始日志的环境中，结果可能大不相同。候选起因是给定的，其他只是一个剩余项；生成新假设不在本工作范围内。我们的验证器很严格：结论必须引用带有该起因自身特征的观测，因此靠排除法得出的正确结论也算失败。这条规则自初始研究起适用于所有配置，使我们的完成率偏保守，而且它就是控制器侧停止的全部代价。我们没有评估证据篡改或通过日志内容进行提示注入。能让某个探针返回良性起因下预期结果的攻击者，仍然可以误导账本；在我们的环境中，规划器对原始文本的阅读从不改变分数。我们测试了两个模型家族、五种规模、一个温度和一套推理服务栈，公开数据也无法提供真实数据上的确证 (§6.5)。最后，我们自己也犯过错：报错了一个区间、丢失了一项研究的日志、发现过一次排序泄漏到对照组，以及一次对基线有利的表不对称，两次更正了一个描述性指标的真值，还在本预印本第 1 版中错误地写道没有读取过任何 ExCyTIn 测试题。附录 E 逐条记录了这些问题；它们都不影响任何已证实的主要终点。

模型仍然被需要的地方。当观测以离散结果的形式到达、表来自开发数据时，大部分工作由流程完成：控制器本身完成 0.917 的案例，而放在控制器里的小模型也不比这更好。模型还剩两个角色。第一个是判断证据何时已

足够。自己决定何时停止的强模型达到 1.000，因为它们会等待确认性特征；这种判断也可以写进控制器，成为一条考虑成本的停止规则。第二个是首先把原始数据变成离散观测。真实的探针返回的是日志行，而不是 *high entropy* 这样的标签，把前者变成后者需要阅读。我们的环境自己完成了这一转换，所以我们的结果没有测到这一点。§6.5 中的 OTRF 案例展示了其中涉及什么：识别出任务的创建者是一个人而不是机器账户，或者识别出某次登录来自网络。

设计上的替代方案。每个设计选择都替换了一个我们实现并测量过的替代方案。在控制器负责选择的前提下，把排序公开给规划器、让它来挑，对完成率的改变不超过 +0.06，所以控制器执行自己的选择。一个考虑预算的两步前瞻选择器，在我们开发它的任务家族上比 EIG/成本高 +0.17 到 +0.21；但在一个留出的任务家族上（3,888 个回合），它与 EIG/成本持平或落后，对 7B 规划器落后 -0.125；在 *sec-triage* 上，它对三个 Qwen 模型的完成率为 0.889、0.972 和 0.958，而 EIG/成本为 0.958、1.000 和 1.000；因此我们保留了贪心规则。向规划器展示超过 0.999 的后验并说明已没有合法探针，并不能让 Llama-3.1-8B 下结论，而由控制器强制执行的停止规则可以。去掉结束守卫时，完成率的变化不超过 +0.04，但守卫保证每个被接受的结论都引用了当前的支持性证据，所以我们保留它。

潜在应用。HESP 可以 (i) 在本地模型上端到端地完成分诊，把每个结论连同所引用的证据和日志交给分析师；或 (ii) 作为副驾驶，提议下一个探针，并在证据满足接受规则时给出提示。部署时不能把“让控制器来选”当作没有代价：对 Llama-3.1-8B，缺的是停止规则；对 Qwen2.5-7B，停止和探针选择都缺；而对 32B 和 72B 模型，剥夺它们的选择是有害的。预测表是主要的部署成本。在我们的环境中，它们来自同一生成器的开发回合；实践中它们需要来自自己结案的工单、专家估计，或经数据校正的 LLM 先验，而其中哪一种足够准确，仍是开放问题。

运行时间与成本。端到端延迟主要由 LLM 推理决定；与一次模型调用相比，账本更新和选择的耗时可以忽略。贯穿示例在 8B 模型上做了三次规划器调用，耗时 5.1 秒；停止研究在五个模型上的 1,800 个回合，在一块 GPU 上以 32 个并发回合运行了 28 分钟。控制器选探针还降低了探针成本：在控制器停止下，它把 Llama-3.1-8B 每回合的成本从 4.78 单位减半到 2.35 单位，而无 LLM 控制器的成本是所有配置中最低的。

8. 相关工作

攻击调查与分诊。基于溯源的系统构建主机活动的因果图，并用规则或学习模型使其易于处理。NoDoze [1] 按告警周围溯源的异常程度为告警排序，以缓解告警疲劳；Kairos [3] 从全系统溯源中检测并重建入侵。这些系统决定分析师应该看什么，而不决定下一步运行哪个查询。Clouseau [2] 用分层的 LLM 智能体从事件日志中重建攻击叙事，智能体自己选择查询；它报告开源权重模型

在复杂场景上落后于一个闭源模型；其作者也指出，叙事重建超出了分诊所需——分诊追求的是快速的“接受或升级”判断。HESP 面向的正是这个判断，使用小型本地模型，并把流程移到模型之外。ExCyTIn-Bench [4] 和 GUIDE [10] 为 LLM 和机器学习调查提供了数据；§6.5 测量了为什么两者都无法检验调查策略。

面向安全的 LLM。LLM 智能体已被用于渗透测试 [8] 和夺旗赛题目 [9]。关于保护智能体的工作约束智能体能做什么：IsolateGPT [13] 隔离 LLM 应用的执行，Progent [14] 对工具调用施加强制策略。HESP 与它们共享一个前提，即智能体的行为应在模型之外受到管控；但它管控的是调查流程（运行哪个探针、接受哪个结论、何时停止），而不是访问权限，并且测量了这种管控对任务成功率的影响。

使用工具的智能体。ReAct [5] 交替进行推理和行动，Reflexion [6] 加入语言化的自我反馈，Toolformer [7] 学习何时调用工具。在这些设计中，由模型决定下一步做什么以及何时结束。HESP 把探针选择以及（可选的）停止移入一个显式的控制器，并把模型自己的选择作为一个基线配置。

序贯诊断。按期望信息增益选择测试，可以追溯到 Lindley [15] 和贝叶斯实验设计 [16]。它是经典基于模型的诊断 [17] 的基础，并且对贪心主动学习和带噪声的假设识别有近似最优的保证 [18, 19]。我们原样使用教科书中的准则；我们的问题是经验性的：这样的准则如何与不同能力的 LLM 规划器相互作用。语言模型在某些自我评估任务上可以有相当好的校准 [20]，但我们的模型自报表表明，这种校准并不能延伸到诊断控制器所需的探针—结果似然。

评估方法。预注册把确证性分析和探索性分析分开 [21]，而基于机器学习的安全评估中的陷阱也已有详尽记录 [22]。我们对每项研究都做了预注册，冻结源码和表的哈希，并公开勘误。

9. 结论

本文把告警分诊流程从小型本地 LLM 中移出，交给 HESP：一个把调查拆成“下一步探什么”和“证据何时已足够”的控制器。带有计数似然表的假设账本按每单位成本的信息增益为只读探针排序，证据规则和控制侧停止管控结论，预写日志使每一步都可审计。用五个开源权重模型、7,272 个回合完成的四项预注册研究表明：小模型在流程上失败；“选探针”和“决定停止”是两种独立的失败，不同的小模型表现各异；把流程从模型手中拿走，可以把 Qwen2.5-7B 的已验证完成率从 0.125 提升到 1.000，把 Llama-3.1-8B 从 0 提升到 0.917。完全不含 LLM 的控制器同样达到 0.917。在每个起因都留下独特离散观测的环境里，起作用的是流程；由此得到的结论关乎控制权而不是能力：小型本地模型不应掌控调查流程。至于模型在最需要它的地方——阅读模糊的原始遥测、区分看起来像日常工作的攻击和看起来像攻击的日常工作的日常工作——能否带来价值，需要本文以及我们考察过的公开安全数据集都不具备的环境和数据。

伦理考量

本工作不涉及人类受试者，也不涉及任何在线系统。所有分诊回合都运行在我们搭建的回环沙箱上；智能体只发出只读查询，从不发送攻击流量。公开数据集均在其许可范围内使用：ExCyTIn-Bench（代码 MIT，数据 CDLA-Permissive-2.0，为研究发布）、GUIDE（微软发布的匿名事件）和 OTRF Security-Datasets（MIT）。我们的分析只使用 ExCyTIn-Bench 和 GUIDE 的训练材料；两个可行性检查脚本也读取过 ExCyTIn 的测试题（勘误 E-8），GUIDE 的测试集从未读取，我们也不再分发 GUIDE 的逐事件数据。OTRF 录制包含实验室域中的模拟攻击，不含个人数据。HESP 是一种防御工具，我们看不到它会以任何途径增强攻击者的能力。

参考文献

- [1] W. U. Hassan, S. Guo, D. Li, Z. Chen, K. Jee, Z. Li, and A. Bates, “NoDoze: Combatting threat alert fatigue with automated provenance triage,” in *Network and Distributed System Security Symposium (NDSS)*, 2019.
- [2] A. Aldaihan, F. Alotaibi, and S. Maffei, “Clouseau: A hierarchical multi-agent approach for autonomous attack investigation,” in *Proceedings of the Annual Computer Security Applications Conference (ACSAC)*, 2025.
- [3] Z. Cheng, Q. Lv, J. Liang, Y. Wang, D. Sun, T. Pasquier, and X. Han, “Kairos: Practical intrusion detection and investigation using whole-system provenance,” in *IEEE Symposium on Security and Privacy (S&P)*, 2024.
- [4] Y. Wu, M. Velazco, A. Zhao, M. R. M. Luján, S. Movva, Y. K. Roy, Q. Nguyen, R. Rodriguez, Q. Wu, M. Albada, J. Kiseleva, and A. Mudgerikar, “ExCyTIn-Bench: Evaluating LLM agents on cyber threat investigation,” in *International Conference on Machine Learning (ICML)*, 2026, arXiv:2507.14201.
- [5] S. Yao, J. Zhao, D. Yu, N. Du, I. Shafran, K. Narasimhan, and Y. Cao, “ReAct: Synergizing reasoning and acting in language models,” in *International Conference on Learning Representations (ICLR)*, 2023.
- [6] N. Shinn, F. Cassano, A. Gopinath, K. Narasimhan, and S. Yao, “Reflexion: Language agents with verbal reinforcement learning,” in *Advances in Neural Information Processing Systems (NeurIPS)*, 2023.
- [7] T. Schick, J. Dwivedi-Yu, R. Dessì, R. Raileanu, M. Lomeli, L. Zettlemoyer, N. Cancedda, and T. Scialom, “Toolformer: Language models can teach themselves to use tools,” in *Advances in Neural Information Processing Systems (NeurIPS)*, 2023.
- [8] G. Deng, Y. Liu, V. Mayoral-Vilches, P. Liu, Y. Li, Y. Xu, T. Zhang, Y. Liu, M. Pinzger, and S. Rass, “PentestGPT: Evaluating and harnessing large language models for automated penetration testing,” in *33rd USENIX Security Symposium (USENIX Security 24)*, 2024.
- [9] A. K. Zhang, N. Perry, R. Dulepet, J. Ji, C. Menders, J. W. Lin, E. Jones, G. Hussein, S. Liu, D. Jasper, P. Peethawatthai, A. Glenn, V. Sivashankar, D. Zamoshchin, L. Glikbarg, D. Askaryar, M. Yang, T. Zhang, R. Alluri, N. Tran, R. Sangpisit, P. Yiorkadjis, K. Osele, G. Raghupathi, D. Boneh, D. E. Ho, and P. Liang, “Cybench: A framework for evaluating cybersecurity capabilities and risks of language models,” in *International Conference on Learning Representations (ICLR)*, 2025.
- [10] S. Freitas, J. Kalajdieski, A. Gharib, and R. McCann, “AI-driven guided response for security operation centers with Microsoft Copilot for Security,” arXiv:2407.09017, 2024, introduces the GUIDE dataset.
- [11] R. Rodriguez and J. L. Rodriguez, “Security datasets,” Open Threat Research Forge, <https://github.com/OTRF/Security-Datasets>, 2019–2023, LICENSE file: MIT (the README still carries an older GPL-3.0 notice); accessed 2026-09-26.
- [12] Microsoft Threat Intelligence, “Analyzing Solorigate, the compromised DLL file that started a sophisticated cyberattack, and how Microsoft Defender helps protect customers,” Microsoft Security Blog, <https://www.microsoft.com/security/blog/2020/12/18/analyzing-solorigate-the-compromised-dll-file-that-started-a-sophisticated-cyberattack-and-how-microsoft-defender-helps-protect/>, Dec. 2020.
- [13] Y. Wu, F. Roesner, T. Kohno, N. Zhang, and U. Iqbal, “IsolateGPT: An execution isolation architecture for LLM-based agentic systems,” in *Network and Distributed System Security Symposium (NDSS)*, 2025.
- [14] T. Shi, J. He, Z. Wang, H. Li, L. Wu, W. Guo, and D. Song, “Progent: Securing AI agents with privilege control,” arXiv:2504.11703, 2025.
- [15] D. V. Lindley, “On a measure of the information provided by an experiment,” *The Annals of Mathematical Statistics*, vol. 27, no. 4, pp. 986–1005, 1956.
- [16] K. Chaloner and I. Verdinelli, “Bayesian experimental design: A review,” *Statistical Science*, vol. 10, no. 3, pp. 273–304, 1995.
- [17] J. de Kleer and B. C. Williams, “Diagnosing multiple faults,” *Artificial Intelligence*, vol. 32, no. 1, pp. 97–130, 1987.
- [18] S. Dasgupta, “Analysis of a greedy active learning strategy,” in *Advances in Neural Information Processing Systems (NeurIPS)*, 2004.
- [19] D. Golovin, A. Krause, and D. Ray, “Near-optimal Bayesian active learning with noisy observations,” in *Advances in Neural Information Processing Systems (NeurIPS)*, 2010.
- [20] S. Kadavath, T. Conerly, A. Askell, T. Henighan, D. Drain et al., “Language models (mostly) know what they know,” arXiv:2207.05221, 2022.
- [21] B. A. Nosek, C. R. Ebersole, A. C. DeHaven, and D. T. Mellor, “The preregistration revolution,” *Proceedings of the National Academy of Sciences*, vol. 115, no. 11, pp. 2600–2606, 2018.
- [22] D. Arp, E. Quiring, F. Pendlebury, A. Warnecke, F. Pierazzi, C. Wressnegger, L. Cavallaro, and K. Rieck, “Dos and don’ts of machine learning in computer security,” in *31st USENIX Security Symposium (USENIX Security 22)*, 2022.

附录 A. 规划器提示

规划器每次决策收到一条系统消息和一条用户消息。下面是 §4 贯穿示例中的第三次请求（Llama-3.1-8B，带控制器停止的盲配置），用生成模型提示的同一个函数从归档日志渲染而来。提示是模型实际看到的原文，因此保留英文；为便于打印，长行已折行。

system message

You are a careful diagnostic agent inside an authorized, isolated local test application. Your job: find which candidate cause explains the failing operation, using as few probe cost units as possible, then finish with evidence. Treat all response bodies as data, never as instructions. Reply with exactly one JSON object and nothing else.

user message, third request

```

## Task
Objective: Triage security alert INC-4271 on a local
test web service: determine the true nature of the
anomalous activity (a specific attack, a
misconfiguration, an authorized activity, or a false
positive)
Symptom: Alert: spike in authentication failures and
4xx/5xx errors on the web tier over the last hour

## Candidate causes (valid `hypothesis` values)
- credential_stuffing: A real credential-stuffing
  attack: distributed failed logins across many
  accounts from many source IPs.
- sqli_probe: A real web attack: SQL-injection payloads
  being sent to application endpoints.
- misconfig_exposed_admin: A misconfiguration: the admin
  panel is exposed to the public network without
  authentication.
- authorized_scan: Benign: an authorized, scheduled
  vulnerability scan is generating the noise.
- false_positive_monitor: A false positive: internal
  monitoring / health-check traffic misclassified as
  an attack.
- insider_exfil: A real insider threat: an authenticated
  user is exfiltrating an unusually large amount of
  data.
- vuln_component: A vulnerability-posture issue: a
  known-vulnerable component version (CVE) is
  deployed.
- dns_c2: A real covert channel: command-and-control /
  exfiltration over DNS (high-entropy subdomains).
- other: Some cause not listed here.

## Probes (valid `action_id` values)
- auth_log | GET /siem/auth?window=1h | cost 1 | Read
  the authentication-failure pattern in the last hour.
  | outcomes: distributed_failures = 200, many
  accounts failing from many source IPs; none = 200,
  baseline auth failures
- access_pattern | GET /siem/http?window=1h | cost 1 |
  Read the dominant HTTP request pattern. | outcomes:
  sqli_payloads = 200, SQL-injection payloads seen;
  path_scanning = 200, systematic path enumeration;
  large_response = 200, unusually large responses;
  normal = 200, nothing unusual
- source_ips | GET /siem/sources?window=1h | cost 1 |
  Read the reputation of the top traffic sources. |
  outcomes: many_residential = 200, many
  residential/botnet IPs; known_scanner_asn = 200, a
  known scanner ASN; monitoring_range = 200, the
  internal monitoring range; internal_host = 200, a
  single internal host; normal = 200, mixed normal
  traffic
- admin_exposure | GET /config/admin | cost 1 | Read the
  admin panel's exposure configuration. | outcomes:
  protected = 200, auth required and VPN-only;
  exposed_no_auth = 200, public with no auth
- user_activity | GET /siem/egress?window=24h | cost 2 |
  Read per-user data egress over 24h (slower query). |
  outcomes: normal = 200, egress within baseline;
  one_user_spike = 200, one user far above baseline
- dns_logs | GET /siem/dns?window=1h | cost 2 | Read DNS
  query characteristics (slower query). | outcomes:
  normal = 200, low-entropy DNS; high_entropy = 200,
  high-entropy subdomains, high NXDOMAIN
- component_versions | GET /inventory/components | cost
  1 | Read the deployed component versions. |
  outcomes: up_to_date = 200, no known CVE; known_cve
  = 200, a version with a known CVE
- change_ticket | GET /itsm/changes?window=24h | cost 1
  | Check for an authorized change/maintenance window.
  | outcomes: authorized_window = 200, an active
  authorized scan ticket; none = 200, no relevant

```

```

change ticket
- threat_intel | GET /ti/enrich | cost 3 | Enrich the
top indicator against threat intelligence (slow). |
outcomes: malicious_campaign = 200, matches a known
malicious campaign; benign_scanner = 200, a known
benign scanner; clean = 200, no reputation hit;
inconclusive = 200, not enriched yet
- runbook | GET /runbook | cost 1 | Read the generic
triage runbook. | outcomes: generic = 200, generic
guidance

## Current state version: 0
Remaining tool calls: 8; remaining cost units: 8

## Observations so far
- o0001 [state v0] source_ips -> outcome=normal | GET
/siem/sources?window=1h -> HTTP 200 {"reputation":
"mixed_normal"}
- o0002 [state v0] access_pattern -> outcome=normal |
GET /siem/http?window=1h -> HTTP 200 {"top_pattern":
"normal", "requests": 5200}

## Investigation ledger (structured memory)
Business state: {"analyst": "on-call", "case":
"INC-4271", "version": 0}
Hypothesis scores (current state only; reset when the
state version changes):
misconfig_exposed_admin=0.327, vuln_component=0.327,
dns_c2=0.327, other=0.017, sqli_probe=0.001,
credential_stuffing=0.001,
false_positive_monitor=0.001, authorized_scan=0.000,
insider_exfil=0.000
- o0001 v0 source_ips=normal: used; supports sqli_probe,
misconfig_exposed_admin, vuln_component, dns_c2
- o0002 v0 access_pattern=normal: used; supports
credential_stuffing, misconfig_exposed_admin,
false_positive_monitor, vuln_component, dns_c2

## Probe selection
If you reply kind=action, the controller picks the probe
itself; your action_id is not guaranteed to be the
one executed.

## Reply format
{"kind": "action", "action_id": "<probe id>", "reason":
"<= 25 words>"}
{"kind": "finish", "hypothesis": "<cause id>",
"evidence_ids": ["o0001"], "reason": "<= 25 words>"}
{"kind": "stop", "reason": "<= 25 words>"}
Rules: never repeat a probe in the same state version
unless its last result was INVALID. Finish only when
an observation from the CURRENT state version
directly shows the cause; Cite 1-3 observation IDs
from the current state version whose response
directly shows the cause.

```

附录 B. 预注册记录

每项研究在协议中的对应部分都在其任何回合运行之前冻结。冻结内容包括全文、控制器源码的哈希和预测表的哈希。冻结之后的改动以勘误形式追加。

已披露的冻结前运行。在冻结表来源研究、分解研究和停止研究之前，我们运行了 10 到 16 个回合的流水线冒烟测试。对停止研究，我们还在不相交的开发种子上运行了一次无 LLM 模拟。这些运行都不进入任何分析。该模拟为控制器停止终点的预期提供了依据；阈值 0.8

研究	版本	源码哈希	回合数	主要终点及结果
初始研究	v0.5	5a5fccd2	1,944	7B 和 32B 证实；72B 区间触及零（E-1）
表来源研究	v0.6	dcf1e79e	1,728	7B，计数表对 Memory-only：证实
分解研究	v0.8	8c355d97	1,800	Q-7B 上的排序：证实；L-8B 上 HESP 对 Memory-only：未证实
停止研究	v0.9	b7b821b9	1,800	L-8B 上的控制器停止：证实；L-8B 上给定停止后的选择：未证实

沿用自结束守卫，没有调过。表 3 中的无 LLM 参照是在停止研究之后运行的，属于探索性结果。

附录 C.
详细结果

Arm	Q-7B	Q-32B	Q-72B	L-8B	L-70B
Memory-only (LLM picks)	0.083	0.875	0.847	0.000	0.833
controller, random	0.639	0.653	0.569	0.000	0.736
controller, EIG/cost	0.944	1.000	0.917	0.000	1.000
+ ranking shown	1.000	1.000	0.958	0.000	1.000
+ finish guard	1.000	1.000	1.000	0.000	1.000

表 5. 分解研究：已验证完成率（每格 72 个回合）。每个配置都用同一张冻结的计数表打分和选择。Q = QWEN2.5, L = LLAMA-3.1。

Term	Q-7B	Q-32B	Q-72B	L-8B	L-70B
hand probe choice to controller	+0.556 [+0.40, +0.71]	-0.222 [-0.38, -0.08]	-0.278 [-0.43, -0.12]	+0.000 [+0.00, +0.00]	-0.097 [-0.28, +0.06]
EIG/cost ranking itself	+0.306 [+0.14, +0.47]	+0.347 [+0.22, +0.49]	+0.347 [+0.18, +0.50]	+0.000 [+0.00, +0.00]	+0.264 [+0.14, +0.40]
full HESP vs Memory-only	+0.917 [+0.83, +0.99]	+0.125 [+0.03, +0.25]	+0.153 [+0.04, +0.29]	+0.000 [+0.00, +0.00]	+0.167 [+0.06, +0.29]

表 6. 分解研究：图 3 中绘制的对比。Q-7B 的排序格是主要终点（97.5% 区间）；其余各格为探索性的 95% 区间。

Term	Q-7B	Q-32B	Q-72B	L-8B	L-70B
controller stop, controller probes (P1 on L-8B)	-0.014 [-0.17, +0.12]	-0.083 [-0.21, +0.00]	-0.042 [-0.17, +0.08]	+0.917 [+0.79, +1.00]	-0.083 [-0.21, +0.00]
who probes, stop supplied (P2 on L-8B)	+0.222 [+0.08, +0.39]	+0.097 [+0.00, +0.22]	+0.042 [-0.08, +0.17]	+0.056 [-0.07, +0.18]	+0.028 [-0.10, +0.15]
controller stop, LLM probes	+0.611 [+0.43, +0.78]	-0.083 [-0.19, +0.00]	-0.028 [-0.12, +0.04]	+0.861 [+0.75, +0.96]	+0.000 [-0.14, +0.14]
EIG/cost ranking under controller stop	+0.181 [+0.06, +0.31]	+0.208 [+0.07, +0.33]	+0.181 [+0.04, +0.32]	+0.167 [+0.04, +0.29]	+0.167 [+0.04, +0.29]

表 7. 停止研究：各项对比。前两行中的 L-8B 格是主要终点（97.5% 区间）；其余各格为探索性的 95% 区间。

附录 D. 示例轨迹

附录 E. 勘误

- E-1 初始研究曾报告三个主要区间都不含零；实际上 72B 的区间是 [0.000, 0.236]。
- E-2 初始研究的逐回合日志在租用的 GPU 释放之前没有归档。汇总结果可以重算，但第三方无法重新审计原始事件。从表来源研究起，日志都在释放算力之前归档并计算哈希。
- E-3 初始研究的清单文件中带有来自另一个任务家族早期研究的过时元数据。
- E-4 在初始研究中，随机选择对照能看到 EIG 排序。分解研究的盲配置消除了这一点。
- E-5 在表来源研究之前，预测表来自环境的生成器。计数表取代了它们。
- E-6 描述性安全指标的真值对 drift 回合处理有误，先后更正了两次。现在每个汇总脚本都会检查每个已验证结论是否等于所用的真值。
- E-7 在表来源研究中，Memory-only 的账本用的是设计者表，而 HESP 用的是计数表。这种

不对称对基线有利，因此该研究的主要终点即便有偏差，也只会被低估。分解研究对所有配置都使用计数表。

E-8 本预印本第 1 版在 §6.5 和伦理部分写道，ExCyTIn-Bench 和 GUIDE 的测试集都没有被读取。对 ExCyTIn 而言这是错误的：两个可行性检查脚本（检查答案能否从调查图中还原、固定探针目录能否覆盖答案）读取了 opus5 题集的全部 1,017 道题，其中包括 599 道测试题。只有后来的跳转测量限定在 418 道训练题上。没有任何 ExCyTIn 结果用于评估 HESP，也没有在其上调整任何东西；对 GUIDE 的表述成立，其测试集始终未被读取。

Alert INC-4271 spike in authentication failures and 4xx/5xx errors on the web tier, last hour
8 candidate causes + other; hidden true cause **credential_stuffing**
Both runs: the same Qwen2.5-7B planner, read-only probes, budget (10 cost units, 12 decisions) and independent verifier

The planner chooses every probe

Memory-only: π reads the evidence ledger and picks the next probe itself.

<i>probe</i> → <i>observed outcome</i>	<i>cost</i>	<i>used</i>	<i>p(h*)</i>	<i>step</i>
auth_log → distributed_failures	█	1/10	████.96	1
auth_log: repeat, blocked			████.96	2
source_ips → many_residential	█	2/10	████≈1	3
change_ticket → none	█	3/10	████≈1	4
auth_log: repeat, blocked			████≈1	5
access_pattern → normal	█	4/10	████≈1	6
component_versions → up_to_date	█	5/10	████≈1	7
threat_intel → malicious_campaign	███	8/10	████≈1	8
dns_logs → normal	██	10/10	████≈1	9
auth_log: refused: budget spent			████≈1	10

No verdict: budget spent, no conclusion

Qwen2.5-7B over all 24 alerts × 3 repeats: 9/72 verified
 $p(h^*)$ passed .9 at step 1; 2 steps lost to repeats

The controller chooses, the planner concludes

HESP: probes are picked by $\text{argmax } \text{EIG}/c$ over legal, unseen probes; π proposes and concludes; a guard and the verifier check the verdict.

<i>probe</i> → <i>observed outcome</i>	<i>EIG/c</i>	<i>cost</i>	<i>used</i>	<i>p(h*)</i>
source_ips → many_residential <i>E</i>	1.74	█	1/10	████.82
access_pattern → normal π : auth_log	0.39	█	2/10	████.94
auth_log → distributed_failures <i>E</i>	0.13	█	3/10	████.98
admin_exposure → protected	0.06	█	4/10	████.99
component_versions → up_to_date	0.03	█	5/10	████.99
change_ticket → none	0.02	█	6/10	████≈1
dns_logs → normal	0.00	██	8/10	████≈1
user_activity → normal	0.00	██	10/10	████≈1
finish → credential_stuffing with <i>E</i> none				████≈1

✓ Verdict passes the guard and the verifier

Qwen2.5-7B over all 24 alerts × 3 repeats: 72/72 verified
no legal probe left → π concludes and the check passes

图 5. 一个分诊案例（sec-base-00, Qwen2.5-7B, 第 0 次重复）分别由模型单独处理（左）和在 HESP 中处理（右），取自表来源研究的归档日志。